MAESTROS A UN CLIC

Seguridad y privacidad

Plataforma web que conecta clientes con profesionales verificados de servicios del hogar en Medellín

Integrantes

- Juan Pablo Castaño
- Brayan Arenas

Institución Universitaria Pascual Bravo
Tecnología en Desarrollo de Software · Sexto semestre
Ingeniería de Software 2

Docente: Maira Perez

Medellín, Octubre de 2026

Controles de seguridad implementados, cumplimiento del tratamiento de datos personales (Ley 1581 de 2012) y acciones pendientes. Se toma como referencia el **OWASP Top 10 (2021)**.

1. Datos que trata el sistema

Dato	Titular	Finalidad	Dónde se guarda	Quién lo ve
Nombre, correo, teléfono	Cliente y profesional	Cuenta y contacto	`users`	El propio usuario. El nombre lo ven además las contrapartes y, en el caso del profesional, el público
Comuna, dirección, coordenadas	Cliente y profesional	Búsqueda por cercanía y dirección del servicio	`users`, `bookings`	El propio usuario. La dirección de una reserva, solo sus partes
Selfie, documento de identidad, certificados	Cliente y profesional	Verificación de identidad (KYC)	Disco **privado**	El propio usuario y los administradores, con URL firmada temporal
Fotos del portafolio y foto de perfil	Profesional / usuario	Mostrar su trabajo y su identidad	Disco público	Cualquiera (es su finalidad)
Mensajes e imágenes del chat	Partes de la reserva	Coordinar el servicio	`messages` y disco **privado**	Solo las dos partes de la reserva
Calificaciones y comentarios	Cliente y profesional	Reputación	`reviews`	Público, en el perfil
Historial de reservas	Partes	Trazabilidad e ingresos	`bookings`, `booking_status_changes`	Las dos partes y los administradores

2. Controles frente al OWASP Top 10

Riesgo	Control en el sistema
A01 Control de acceso roto	Middleware de rol y Policies por recurso en cada acción (dueño, partes de la reserva); el perfil de un cliente solo lo ve el profesional con quien tiene una reserva; los usuarios bloqueados no acceden. Pruebas de 401 y 403 por endpoint
A02 Fallas criptográficas	Contraseñas con bcrypt; HTTPS y `wss` en producción; URLs firmadas con la clave de la app para los archivos privados
A03 Inyección	Consultas con el ORM y parámetros enlazados; validación de toda entrada con FormRequest; Vue escapa el contenido al mostrarlo (el chat no interpreta HTML)
A04 Diseño inseguro	Reglas de negocio centralizadas en servicios: máquina de estados, bloqueo de la agenda en una transacción para evitar dobles reservas, chat cerrado al terminar la reserva

Riesgo	Control en el sistema
A05 Configuración insegura	`APP_DEBUG=false` en producción, errores con formato estándar sin trazas, lista de verificación de despliegue. **Pendiente:** limitar CORS al dominio del frontend
A06 Componentes vulnerables	Auditoría de dependencias en cada pull request
A07 Fallas de autenticación	Tokens de Sanctum (se revocan al cerrar sesión, al restablecer la contraseña, al bloquear la cuenta y al eliminarla), máximo 10 intentos por minuto en login, registro y recuperación, contraseña de 8 caracteres o más, recuperación que no revela qué correos existen y cierre de sesión tras 15 minutos de inactividad (HU050). **Pendiente:** vencimiento de los tokens en el servidor (`sanctum.expiration`)
A08 Integridad de datos	CI obligatoria y check Guardas; las migraciones existentes no se editan; historial de estados auditable
A09 Registro y monitoreo	Log de la app con rotación diaria, historial de cambios de estado con autor y fecha, monitoreo de salud (`/up`)
A10 SSRF	El servidor no hace peticiones a URLs que entregue el usuario

3. Cumplimiento de la Ley 1581 de 2012

Principio o derecho	Cómo se atiende	Estado
Finalidad	Cada dato tiene una finalidad declarada (tabla de la sección 1)	✅
Seguridad	Controles de la sección 2; documentos y adjuntos en almacenamiento privado	✅
Acceso y circulación restringida	El perfil público no muestra datos de contacto; el chat solo lo ven las partes	✅
Libertad (autorización previa)	Casilla obligatoria de aceptación de la *Política de tratamiento de datos* en el registro, con la fecha y la versión aceptadas	⚠️ Pendiente
Transparencia	Publicar la política (finalidades, derechos, canal de contacto del responsable)	⚠️ Pendiente
Consulta y rectificación	El usuario ve y edita sus datos, ubicación y foto desde su cuenta (HU009, HU022, HU031, HU032)	✅
Supresión	Eliminación de cuenta con anonimización: se borran datos de contacto, ubicación, fotos, documentos de verificación, favoritos y sesiones, y se conservan las reservas, reseñas y chats de la otra parte con el nombre "Usuario eliminado" (HU023, D12)	✅

4. Acciones pendientes

#	Acción	Responsable sugerido	Prioridad
1	Política de tratamiento de datos y aceptación obligatoria en el registro (campo `privacy_accepted_at` en una migración nueva)	Módulo cuenta	Alta
2	Limitar CORS al dominio del frontend en producción	Despliegue	Alta
3	Vencimiento de los tokens en el servidor (`sanctum.expiration`); el cierre por inactividad del navegador ya está (HU050)	Módulo cuenta	Media
4	Límite de frecuencia en el envío de mensajes del chat	Chat	Baja